PATH TRAVERSAL REPORT

1. Lab Name

PortSwigger: File path traversal, simple case

2. Objective

To exploit a path traversal vulnerability in an image loading function to read arbitrary files from the server.

3. Vulnerability/Concept

Path Traversal (also called Directory Traversal) occurs when an application uses user input to construct file paths without proper validation.

Attackers can use `../` sequences to navigate outside the intended directory and access sensitive files.

In this lab, the image filename parameter is vulnerable. By injecting `../../../etc/passwd`, we can read the system's password file.

4. Testing Approach

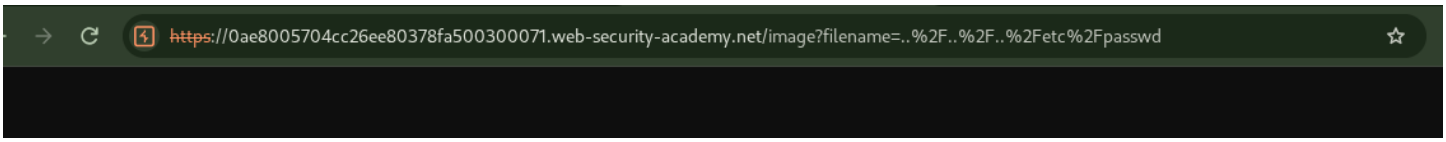
1. Navigated to the shopping website
2. Clicked on a product
3. Observed image URL: `/image?filename=product.jpg`
4. Modified filename to: `../../../etc/passwd`
5. Server returned the contents of `/etc/passwd`
6. Lab solved

5. Evidence/Screenshots

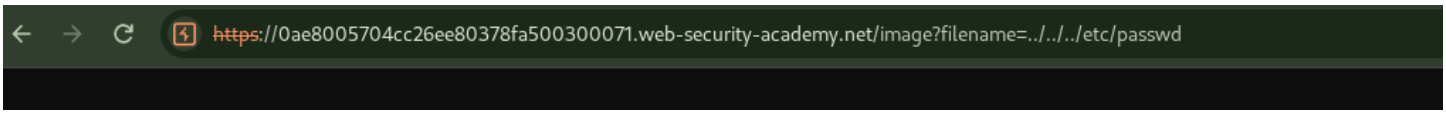
1. Lab completion - "Solved" banner



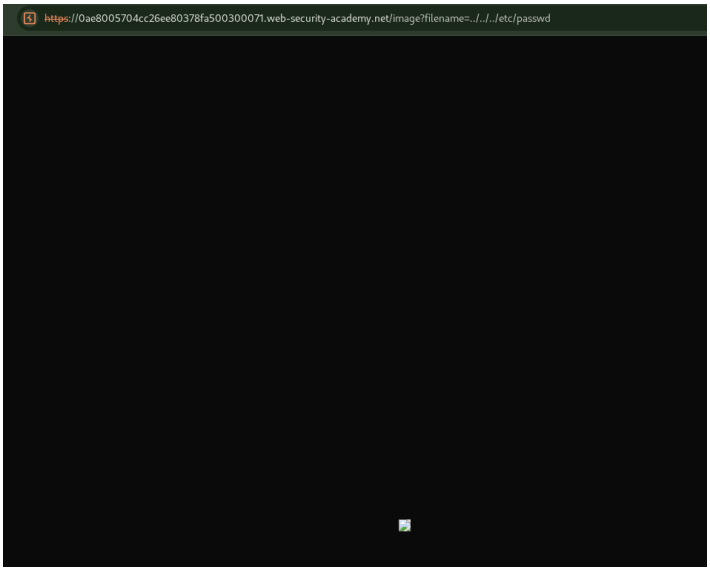
2. URL with path traversal payload

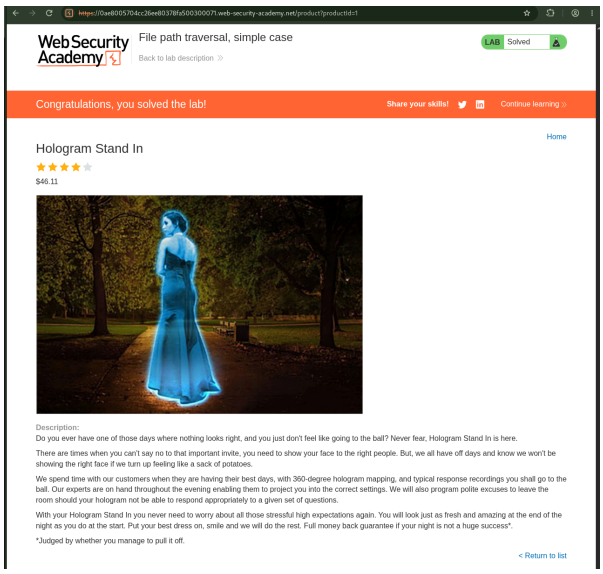


3. `/etc/passwd` contents displayed



4. Screenshot 4: Full page evidence





6. Impact

- Read sensitive files (passwords, configs)
- Access source code
- Steal credentials
- Map internal system structure
- Potential remote code execution

---

7. Remediation

- Validate and sanitize file paths
- Use whitelist of allowed filenames
- Don't use user input directly in file paths
- Use `` `basename()` `` to strip directory components
- Chroot or sandbox file access
- Run with least privileges

---

8. What You Learned

- Path traversal uses `` `../` `` to escape directories
- User input in file paths is dangerous
- Sensitive files like `` `/etc/passwd` `` can be read
- Input validation prevents path traversal
- Whitelisting is better than blacklisting
